

Clear Desk and Clear Screen Policy

FortisAid Health Technologies

Policy Number: FTAID-POL-007

Version 1.0 | Effective: 18 Feb 2026

Document Control Page

Field	Details
Policy Title	Clear Desk and Clear Screen Policy
Policy Number	FTAID-CDC-POL-007
Author	Adanna Chika-Odi
Policy Owner	Chief Information Security Officer
Reviewer	[Role/Group 2]
Approver	CEO of FortisAid
Version	1.0
Effective Date	18 February 2026
Current Review Date	18 February 2026
Next Review Date	18 February 2027
ISO 27002:2022 Domain	Physical Control
ISO 27002:2022 Sub-domain	Clear desk and clear screen, Information Classification, Physical Security Monitoring
ISO 27002:2022 Control	7.7, 7.4, 5.12
Related Policies	Acceptable use of information and other associated assets, Securing offices, rooms, and facilities, Classification of information
Approval Status	Approved

Approval Evidence

Approver: Chief Executive Officer



Date: 26th February, 2026

Purpose and Scope

Purpose:

This policy ensures that sensitive information, including Patient Health Information (PHI) and Electronic Health Records (EHR), is protected from unauthorized access by maintaining clear desks and secured screens in all FortisAid facilities.

It supports the confidentiality and integrity of healthcare data in compliance with regulatory and information security requirements.

Scope:

This policy applies to all employees, clinicians, contractors, and third-party personnel working within FortisAid offices, clinical environments, and remote work locations.

It covers all physical and digital workspaces where sensitive information is processed, displayed, or stored.

FortisAid Context:

As a healthcare organization handling confidential patient data, FortisAid must prevent accidental or intentional disclosure of PHI in shared clinical spaces, reception areas, nursing stations, administrative offices, and remote work environments.

ISO 27002:2022 Alignment

ISO Domain	ISO Sub-domain	Control Number	How this policy addresses it
Physical Controls	Clear Desk and Clear Screen	7.7	Ensures sensitive information is not left unattended in physical or digital form.
Organizational Controls	Information Classification	5.12	Supports proper handling of classified healthcare information.
Physical Controls	Physical Security Monitoring	7.4	Reduces risk of unauthorized viewing or access in controlled areas.

Threats and Key Risks (Healthcare Context)

Threats:

- Unauthorized viewing of patient records left on desks.
- Shoulder surfing in clinical or reception areas.
- Exposure of PHI on unlocked computer screens.
- Loss or theft of printed medical documents.

Key Risks to FortisAid:

Risk 1: Breach of PHI resulting in regulatory penalties under healthcare data protection laws and reputational damage.

Risk 2: Accidental disclosure of sensitive patient information in shared or public-facing areas.

Risk 3: Loss of trust from patients and stakeholders due to poor information handling practices.

Policy Statements / Requirements

Clear Desk Requirements

- Sensitive documents, including patient files and reports, must not be left unattended on desks.
- All confidential documents must be stored in locked cabinets or secure storage when not in use.
- Printed PHI must be disposed of using approved secure shredding facilities.
- Portable storage devices containing sensitive data must be secured when not in use.

Clear Screen Requirements

- Computer screens must be locked when unattended (automatic screen lock after defined inactivity period).
- Users must log out of clinical and administrative systems at the end of each session.
- Privacy screen filters must be used in high-traffic or public-facing areas.
- Remote workers must ensure screens are not visible to unauthorized individuals.

Compliance and Enforcement

Monitoring Activities:

- **Frequency:** Quarterly physical security inspections and periodic compliance spot checks.
- **Responsible Role:** IT Security Team, Facilities Management, and Departmental Managers.
- **Evidence Stored:** Inspection reports, audit logs, and corrective action records.

Non-Compliance:

Failure to comply may result in disciplinary action in accordance with FortisAid's HR and governance procedures and may be escalated where regulatory obligations apply.

Training and Awareness

- Mandatory information security awareness training within 30 days of joining.
- Annual refresher training for all staff.
- Role-specific guidance for frontline clinical staff and reception personnel handling PHI.

Review and Revision

This policy will be reviewed annually or following significant security incidents or regulatory updates.

Next scheduled review: 18 February 2027

References

- ISO/IEC 27002:2022
- UK GDPR / Data Protection Act 2018
- HIPAA Security Rule
- NHS Data Security and Protection Toolkit
- FortisAid Governance Structure